

ELISA | Evidencia de seguridad - sesión 13

Implementación equivalente en FastAPI + Django ORM + PostgreSQL. Las guías describen Spring Boot; este proyecto utiliza otra pila.

Controles implementados

Requisito	Evidencia en ELISA
Contraseñas BCrypt	Alta y actualización de colaboradores guardan únicamente el hash; la API nunca devuelve password_hash.
JWT y roles	Login emite access y refresh JWT; rutas privadas exigen Bearer. Los permisos L1-L5 se verifican en los endpoints.
XSS y validación	DTO Pydantic rechaza HTML, entidades codificadas y campos obligatorios vacíos; la salida JSON escapa <, > y &.
CORS e inyección SQL	Orígenes, métodos y cabeceras explícitos. Las búsquedas utilizan filtros parametrizados de Django ORM.

Resultados verificados

```
Comando: python manage.py test clients --settings=core.test_settings --noinput
Resultado: Ran 11 tests ... OK
PostgreSQL local: bcrypt=True; longitud del hash=60
Casos: XSS=422; sin token=401; rol insuficiente=403; CORS externo=sin ACA0; búsqueda SQLi=lista vacía
```

Interpretación OWASP

El control de acceso basado en roles reduce el riesgo de operaciones no autorizadas; BCrypt protege las contraseñas almacenadas frente a exposición directa; la validación y codificación de salida reducen la superficie de XSS; y las consultas parametrizadas del ORM evitan que el texto de búsqueda se ejecute como SQL. Estas pruebas no sustituyen una auditoría de seguridad ni demuestran protección total.

Alcance y reproducibilidad

Las 11 pruebas usan una base SQLite aislada para no alterar PostgreSQL. Se verificó por separado en la base PostgreSQL local que el hash del administrador usa el prefijo BCrypt y mide 60 caracteres. No se muestra el hash completo ni ningún token o contraseña. No se ha hecho commit o push.

Fuentes: Ficha de Trabajo sesion13.docx; taller_Sesion13.docx; backend/clients/tests.py.